

Московский Физико-Технический Институт
(Национальный исследовательский университет)

Кафедра защиты информации

Дисциплина: «Защита информации»

КУРСОВАЯ РАБОТА (Проект)

MailDefender: фильтрация ZIP+LNK вложений и ИИ-анализ
почтовых сообщений

Выполнили:

Шевяхов Е. И., Б01-204

Осипов А. С., Б01-204

Тулупов Н. Д., Б01-204

Глушнев К. Н., Б01-204

Маков С. К., Б01-204

Проверила:

Мозолина Н.В.

Долгопрудный 2025

1 Актуальность и мотивация

Электронная почта остаётся одним из основных каналов первичного проникновения в инфраструктуру. В реальных инцидентах последних лет целевые группы (АРТ и финансово мотивированные хакеры) активно используют фишинговые письма с архивами и ярлыками Windows .lnk внутри ZIP-файлов. Такой приём позволяет обходить самые простые почтовые фильтры и «скрывать» запуск вредоносного кода за привычным для пользователя действием: «распаковал архив, два раза кликнул по ярлыку».

Подобные техники подробно описаны в недавних исследованиях, например:

- анализ масштабной шпионской кампании PhantomCore от Positive Technologies: [см. ссылку](#)
- обзор атак АРТ-групп и финансово мотивированных акторов на промышленные предприятия во втором квартале 2025 года от Kaspersky ICS CERT: [см. ссылку](#)

В отчётах вендоров по инцидентам (в том числе по кампаниям против промышленных и государственных организаций) регулярно встречаются одинаковые паттерны:

- ZIP-вложения с ярлыками и скриптами как первый шаг цепочки заражения;
- фишинговые письма, имитирующие деловую переписку (счета, тендеры, кадровые вопросы);
- использование легитимного ПО и легитимного сетевого протокола (SMTP) для доставки полезной нагрузки.

На этом фоне становится актуальной задача: даже в небольшой лабораторной среде показать, как простое техническое правило и лёгкая интеграция с моделью ИИ позволяют отсеять целый класс атак ещё до доставки письма до пользователя или почтового сервера.

Цель проекта MailDefender — реализовать компактный лабораторный стенд для проверки почтовых сообщений, который:

- гарантированно блокирует письма с ZIP-вложениями, содержащими .lnk-файлы;
- может дополнительно использовать модель ИИ для эвристической оценки содержимого письма;
- разворачивается в Docker и позволяет наглядно демонстрировать работу защиты на безопасных тестовых примерах.

2 Постановка задачи

Чтобы решить поставленную проблему, мы сформулировали несколько ключевых задач:

- 1) Разобраться, как именно злоумышленники проводят атаки через ZIP-архивы с .lnk-файлами, и выделить простое правило, которое надёжно блокирует такой тип вложений.
- 2) Создать лёгкий модуль проверки почты, который умеет выявлять подозрительные ZIP-файлы и принимать решение о том, можно ли доставлять письмо пользователю.
- 3) Сделать удобный инструмент для тестирования — веб-страницу и небольшой клиент, позволяющий отправлять письма и сразу видеть, как работает фильтрация.
- 4) Добавить при желании дополнительный уровень анализа с помощью ИИ, чтобы модель могла отметить письма с фишинговыми признаками даже тогда, когда вложения выглядят безобидно.
- 5) Собрать всё в единое демонстрационное окружение, которое поднимается в пару команд и позволяет быстро показать работу защиты на реальных примерах.

3 Архитектура и реализованные компоненты

Проект состоит из нескольких связанных частей, каждая из которых отвечает за свой этап проверки письма.

Конфигурация

В отдельном модуле хранятся все основные настройки: пути к шаблонам, ограничения на размер сообщений и параметры для работы ИИ. Благодаря этому все компоненты пользуются единым набором настроек, и поведение системы легко менять через переменные окружения.

Правило ZIP+LNK

Основой всей защиты является модуль, который проверяет письма на наличие ZIP-архивов с ярлыками `.lnk` внутри. Он разбирает письмо, просматривает вложения и, если находит такой архив, сразу помечает письмо как опасное. Это простое правило перекрывает один из самых популярных векторов атак, используемых в реальных фишинговых кампаниях.

Система также аккуратно обрабатывает повреждённые или некорректные ZIP-файлы, не позволяя таким письмам проходить дальше.

Слой анализа с ИИ

Дополнительно можно включить ИИ-проверку текста письма. Модель получает краткое описание письма (заголовки, текст и список вложений) и классифицирует его как безопасное или подозрительное. Это помогает выявлять фишинговые письма даже тогда, когда вложения не содержат технических признаков вредоносности.

Если ИИ считает письмо опасным, система блокирует его так же, как и в случае ZIP+LNK.

Веб-клиент и консольные инструменты

Для удобства тестирования реализован простой веб-интерфейс. Через него можно отправлять письма, прикладывать файлы и сразу видеть результат работы защиты. Также доступны готовые примеры «опасных» вложений, чтобы можно было быстро продемонстрировать блокировку.

Для работы в терминале предусмотрена лёгкая CLI-утилита, позволяющая проверять файлы `.eml` и получать вердикт прямо в консоли.

Кроме того, всё окружение разворачивается в Docker: поднимается Mailpit как тестовый SMTP-сервер и клиент MailDefender, что делает демонстрацию полностью воспроизводимой.

4 Как решение выполняет свою задачу

Блокировка ZIP+LNK-атак

Основой всей защиты является правило, которое отслеживает ZIP-архивы с ярлыками `.lnk` внутри. Это очень простой, но при этом эффективный признак: если внутри архива есть ярлык — письмо сразу считается подозрительным.

Такой подход замечателен тем, что:

- не нужно разбираться в содержимом самого ярлыка — достаточно факта его наличия;
- блокируется целый класс атак, которые активно используются в реальных кибершпионских кампаниях;
- решение остаётся лёгким, прозрачным и хорошо объяснимым.

Для демонстрации используется специально подготовленный безопасный архив — он позволяет показать работу защиты, не рискуя чем-либо.

Дополнительная роль ИИ

ИИ в MailDefender — это дополнительный уровень проверки, который помогает распознать фишинг по тексту письма. Даже если вложения выглядят нормальными, модель может заметить подозрительные формулировки, ссылки или необычный тон сообщения.

Важно, что:

- использование ИИ полностью необязательно — система работает и без него;
- ИИ включается как «второе мнение» при необходимости;
- если модель не может дать ответ, письмо не пропускается тихо — об ошибке сообщается явно.

Так два подхода — техническое правило и анализ текста — хорошо дополняют друг друга и позволяют закрывать как очевидные, так и более скрытые угрозы.

Наглядность и простота демонстрации

Проект легко запускается в Docker и сразу готов к демонстрации:

- Mailpit работает как тестовый почтовый сервер и показывает все доставленные письма;
- веб-клиент MailDefender позволяет отправлять письма, прикладывая файлы и моментально видеть результат проверки.

Показ работы системы может выглядеть так:

1. отправляем обычное письмо — оно проходит без проблем;
2. отправляем письмо с ZIP+LNK — система блокирует вложение и объясняет почему;
3. включаем ИИ, отправляем фишинговый текст — модель отмечает письмо как опасное.

В итоге становится наглядно видно, как простое защитное правило и анализ текста эффективно разрывают тот же путь атаки, который встречается в реальных инцидентах.

5 Вывод

В рамках проекта MailDefender разработан компактный, но показательный прототип системы фильтрации почтовых сообщений:

- реализовано простое и надёжное правило блокировки ZIP+LNK-вложений, отражающее реальные векторы атак;
- добавлен опциональный уровень ИИ-аналитики, позволяющий выделять социально-ориентированные атаки даже при «чистых» вложениях;
- создано удобное лабораторное окружение на Docker с веб-клиентом и Mailpit, пригодное как для демонстраций, так и для дальнейших экспериментов.

Такой стенд можно развивать дальше: добавлять новые правила (макросы, подозрительные ссылки), наращивать набор тестовых кейсов, сравнивать эффективность различных моделей ИИ. Но уже в текущем виде он решает поставленную задачу: наглядно показывает, как сочетание простых технических фильтров и современных моделей помогает защитить почтовую инфраструктуру от актуальных угроз.